

Incident Playbook — Ransomware

Step-by-step response to ransomware events

Document ID: BVT-IRP-046

Version: 1.0

Issued: July 02, 2026

Effective Date: _____

FIRST MOVES: Isolate, don't power off (preserves memory evidence) — unless encryption is visibly in progress on that host, then pull network/power. Protect the backups BEFORE anything else: verify backup console access, rotate its credentials, and confirm immutability/retention hasn't been tampered with.

Immediate Actions (First 60 Minutes)

- 1 Declare SEV-1; assign IC, Lead Responder, Scribe; start timeline.
- 2 Network-isolate affected hosts via EDR; if EDR unavailable, disable switch ports/WiFi for affected segments.
- 3 Secure the backup platform: change credentials, verify recent restore points exist and are intact, disconnect any backup repository reachable as a writable share.
- 4 Disable compromised/privileged accounts observed in the attack path; revoke sessions; reset domain admin credentials from a known-clean system.
- 5 Identify the strain (ransom note, extension) and check for known decryptors (No More Ransom project).
- 6 Notify client leadership (Client Liaison); advise contacting cyber insurer and breach counsel immediately — insurer approval is often required before engaging vendors or negotiating.

Assessment

- Scope: which hosts encrypted, which merely touched; check DCs, hypervisors, and file servers first.
- Exfiltration check: egress logs, cloud storage tools, archive utilities (double-extortion is the norm — assume data theft until disproven).
- Entry vector: exposed RDP/VPN, phishing, vulnerable edge device — must be identified and closed before recovery.
- Persistence: new accounts, scheduled tasks, services, GPO changes, rogue remote-access tools.

Recovery Decision Path

Condition	Path
Clean, tested backups exist beyond attacker dwell time	Rebuild/restore: wipe or replace hosts, restore data, staged reconnection, credential reset environment-wide
Backups compromised or insufficient	Engage forensics/negotiation specialists via insurer & counsel; ransom payment is a client + counsel + insurer decision (note OFAC sanctions risk) — BVTech does not negotiate or pay independently
Partial encryption	Prioritize by RTO tiers in the DR plan; restore critical services first

Recovery Hardening (Before Reconnection)

- Reset ALL credentials (including service accounts and krbtgt twice where AD compromised); rotate API keys and VPN secrets.
- Patch/replace the entry vector; enforce MFA everywhere; remove legacy access paths.
- EDR on every host before it rejoins; heightened monitoring 30 days; verify backup jobs green post-recovery.

Closeout

- Breach notification analysis with counsel (BVT-IRP-052) — exfiltration usually triggers obligations.
- Full incident report, root cause, and control improvements; client debrief with prevention roadmap; update tabletop scenarios.